JOURNAL OF CYBERSECURITY

Journal of Cybersecurity, 2019, 1–16
doi: 10.1093/cybsec/tyz010
Research paper

Research paper

Embracing and controlling risk dependency in cyber-insurance policy underwriting*

Mohammad Mahdi Khalili [1,*], Mingyan Liu[1] and Sasha Romanosky[2]

[1]Department of Electrical Engineering and Computer Science, University of Michigan, Ann Arbor, MI 48109, USA and [2]RAND Corporation, Arlington, VA 22202, USA

*Corresponding address: Department of Electrical Engineering and Computer Science, University of Michigan, Ann Arbor, MI 48109, USA. E-mail: khalili@umich.edu

Received 25 October 2018; revised 23 February 2019; accepted 12 July 2019

Abstract

This article highlights how cyber risk dependencies can be taken into consideration when underwriting cyber-insurance policies. This is done within the context of a base rate insurance policy framework, which is widely used in practice. Specifically, we show that there is an opportunity for an underwriter to better control the risk dependency and the risk spill-over, ultimately resulting in lower overall cyber risks across its portfolio. To do so, we consider a Service Provider (SP) and its customers as the interdependent insurer's customers: a data breach suffered by the SP can cause business interruption to its customers. In underwriting both the SP and its customers, we show that the insurer can increase its profit by incentivizing the SP (through a discount on its premium) to invest more in security, thereby decreasing the chance of business interruption to the customers, and increasing social welfare. For comparison, we also consider a scenario where the insurer underwrites only the SP's customers (but not the SP), and receives compensation from the SP's insurance carrier when losses are attributed to the SP. We show how the insurer's best strategy is to underwrite both the SP and its customers. We use an actual cyber-insurance policy and claims data to calibrate and substantiate our analytical findings.

Introduction

Increasing costs emanating from cyberattacks and data breaches, such as legal fees, crisis management, business interruption, and ransom payments threaten organizations and businesses. To mitigate these losses organizations are increasingly turning to cyber-insurance in order to transfer some or all their risk to the insurer [1]. Like all other forms of insurance, cyber-insurance is primarily a method of risk transfer: a risk-averse insured pays an insurer a premium in exchange for coverage in the event of a loss [2–4], and there have been a number of studies on this market mechanism, e.g., when provided by a cyber insurer [5], a security vendor [6], or through a coalitional insurance mechanism among organizations [7].

But insurance carriers are also risk-averse, cost-minimizing entities that face multiple challenges. Not only must they effectively assess and differentiate risks of, and between, individual firms, but they must also manage systemic risk (also known as correlated or aggregate risk) across a portfolio of policies in order to reduce catastrophic losses. On the latter, insurance carriers often struggle to effectively identify indicators of systemic risk and understand how to manage their portfolio of policies to reduce their own costs [8]. A major cause of systemic risk is business interdependencies between organizations as a result of outsourcing or supply chain relationships. In these cases, the state of security of one firm depends not only on its own effort but also other firms' efforts [9–18]; and in this world of increasing connectedness between today's businesses, risks can spill over easily and quickly from one firm to another. For instance, a breach at a credit card processing vendor can lead to major losses by retailers, or an outage at a network service provider (such as Amazon or Microsoft cloud services) can result in business interruption to a large number of

© The Author(s) 2019. Published by Oxford University Press.
This is an Open Access article distributed under the terms of the Creative Commons Attribution-NonCommercial-NoDerivs licence (http://creativecommons.org/licenses/by-nc-nd/4.0/), which permits non-commercial reproduction and distribution of the work, in any medium, provided the original work is not altered or transformed in any way, and that the work is properly cited. For commercial re-use, please contactjournals.permissions@oup.com

Downloaded from academic.oup.com/cybersecurity/article/5/1/tyz010/5601219 by guest on 18 October 2026

customers.[1] Moreover, this kind of risk dependency can lead firms to free ride off other firms' efforts and under-invest in security [20–22].

In particular, we consider two main reasons driving the concern over interdependent risk. First, it is more likely that simultaneous loss events could happen to interdependent agents, which would threaten the insurer's capital limit or other liquidity requirements. Second, in the event that a data breach or other loss events could be attributed to a third party, such as a service provider (e.g., a cloud platform vendor) who may be insured by a different carrier, the insurer of the primary party may seek to recover some or all of its losses from the third party's insurer/policy, thereby reducing its own risk exposure. If, on the other hand, the primary party's insurer underwrites both the primary firm and its third party, then even if the loss to the primary could be attributed to the third party, the insurer would effectively be "suing itself" for the losses. All this has led to a strong desire among insurance carriers to minimize this type of risk dependency. However, a proper solution continues to elude insurance carriers, reinsurers, and modeling firms [23].

It is thus of considerable interest to cyber-insurance underwriters to understand how to effectively manage not only individual firm risk, but overall portfolio risk in the presence of interdependent systems among policy holders. One device available to them is the ability to provide incentives (premium discounts) directly to firms that demonstrate improved security posture. While this may help reduce individual firm risk, it is unclear how this may help resolve systemic risk from interdependent business relationships.

To this end, the main purpose of this study is to develop an understanding of the cyber-insurance market in the presence of interdependent (and risk adverse) agents in a realistic underwriting setting. Our previous work using a contract-theoretic approach [24] has shown that contrary to the common dependency-avoidance practice mentioned above, there is an unrealized incentive for an insurer to underwrite dependent risks. Paradoxically, the existence of risk dependency among a network of insureds allows the insurer to jointly design polices that incentivize the insureds to (collectively) commit to higher levels of effort, which can simultaneously result in improved state of security for all as compared to a portfolio of independent insureds, and in improved profits for the insurer. We further examined whether these observations continue to hold when an insurer can recover a part of the loss suffered by an insured through a third-party liability clause when the loss can be attributed to another insured (the third party) underwritten by a different insurer [25]. Even with this loss recovery as an alternative, conditions exist where it is beneficial both from a security perspective and a profit perspective for an insurer to underwrite both interdependent insureds, precisely because this allows the insurer to control the risk dependency and incentivize both to commit to higher security efforts.

While [24, 25] used a rather simplified and stylized contract model somewhat detached from the actual insurance underwriting practice, in the present article we adopt a standard underwriting framework commonly used in the insurance industry, and analyze different portfolio choices by a underwriter and quantify their impact on the resulting profit, risk reduction, as well as social welfare. Specifically, we consider a service provider (SP) and its customers, and use both analytic and computational techniques to model three portfolio alternatives available to the insurance carrier: insure just the service provider, insure both the service provider and its customers, or insure just the service provider's customers. The strategic decision centers on how the insurer can induce the parties to reduce their risk while maximizing its own profits. We examine how these incentives can be used to reduce the direct risk to one party, as well as to reduce indirect risks to dependent firms. We also examine social welfare implications and use data from an actual cyber-insurance policy, as well as one of the only sources of insurance claims data, to calibrate and substantiate our analysis. Our results show that the insurer is able to achieve higher profit by insuring all agents (SP and its customers) provided it appropriately incentivizes the SP to improve its state of security. This is because risk reduction by the SP leads to risk reduction for its customers, thus the benefit has a multiplicative effect. This ultimately not only allows the insurer to be able to take on the risk of all agents without hurting its profit, but also leads to higher social welfare.

Overall, our results suggest a novel and improved approach to cyber-insurance policy design that presents a new way of thinking about systemic risk and cyber risk dependency: to embrace and manage these risks, rather than avoid them. While we acknowledge the warranted caution against concurrent and correlated loss events, the emphasis of the present paper is to highlight a definitive silver lining behind risk dependency, and an opportunity to actively work toward reducing overall cyber risks in an ever-escalating and interconnected threat landscape.

The remainder of the article is organized as follows. We provide an example of actual cyber-insurance policy underwriting in 'Computing premiums using base rates – examples from an actual underwriter' section. We then present our model and analysis in 'The insurance policy model and analysis' section, followed by numerical examples in 'Numerical examples' section. Discussions are given in 'Discussions' section and 'Conclusion' section concludes the article.

Computing premiums using base rates – examples from an actual underwriter

In this section, we briefly describe a common approach to calculating cyber-insurance premiums. The calculation begins by first selecting the *base premium* and a *base retention* (deductible) from previously defined lookup tables. The base premium is then modified through a linear product of additional factors. While different carriers use different values and types of factors in their premium expression, there are a number of commonly used factors.

Below, we provide an example of such a calculation using an actual cyber-insurance policy (see the Supplementary Appendix to view the full rate schedule), with methods commonly found throughout the insurance industry. First, the base premium and retention are determined using table lookups, where the asset size (for financial institutions) or annual revenue (for non-financial institutions) of the insured maps to assigned values, with both the rate and the retention amounts increasing in asset or revenue size. For instance, a financial institution of asset value up to \$100 M would be charged a base rate of \$5,000 for a base retention of \$25,000, while

1 Another form of systemic risk can occur when a common vulnerability or system configuration shared across many policy holders may be exploited simultaneously, leading to multiple breaches, and subsequent insurance claims. Indeed, a number of past virus and Trojan outbreaks in the past 20 years have been caused by exploiting a common vulnerability (e.g., Sasser, SQL Slammer). Similarly, the massive WannaCry and NotPetya ransomware attacks of 2016 were also caused by exploiting a common vulnerability across many firms [19]. Note, however, the focus of this article concerns systemic risks caused by interdependent systems.

Downloaded from academic.oup.com/cybersecurity/article/5/1/tyz010/5601219 by guest on 18 October 2026

a firm of assets between \$500 M and \$1B would be charged a base rate of \$11,000 for a base retention of \$100,000, all for a nominal coverage amount of \$1 M. On the other hand, a non-financial firm with annual revenue between \$5 M to \$10 M would be charged a base rate of \$7,500 for a base retention of \$25,000.

This base rate is then multiplied by a number of factors, with each factor modifying the base rate roughly between –20% and +20% with a few exceptions, as shown below.

- **Industry factor:** Based on the type of business, an industry hazard is determined, with higher-risk businesses receiving a larger multiplier. For instance, agricultural and construction businesses receive the smallest hazard value (less risky) while web service providers receive the larger hazard value (more risky), as shown in Table 1.
- **Retention factor:** This factor depends on the retention (deductible) that the insured selects. Retention factor decreases as a function of the retention that the insured chooses, as shown in Table 2.
- **Increased limit factor:** This is a factor driven by the limit of the coverage: it is 1.0 if the insured accepts the default limit (corresponding to the base rate and base retention); it exceeds 1.0 if the insured wants to increase this limit, and falls below 1.0 if the insured asks for a lower coverage limit, as shown in Table 3.
- **Co-insurance factor:** This factor is less than 1.0 if the insured accepts to pay a share of the payment made against a claim. The value of this factor depends on the amount of the share that the insured accepts to pay. Table 4 lists some of the co-insurance factors based on the co-insurance percentage.
- **Third-party modifier factors:** This factor depends on the third party service provider. If the insured does not use any third party service, this factor is equal to 1.0. Otherwise, this factor is set based on the third party service and the agreement between the insureds and the service provider, but is not a function of the security posture of the third-party.
- **Optional coverage grants:** In addition to the base coverage, the policy holder may purchase coverage for additional exposures, such as privacy costs or crisis management. Each additional coverage is calculated by multiplying the base rate by a number of factors including an option-specific modifying factor. For instance, the option of privacy notification expense uses a factor of 0.15, while the option of crisis management expense uses a factor of 0.02.

Table 1: Industry hazard table.

Industry	Factor
Agriculture	0.85
Construction	0.85
Not-for-profit organizations	1.00
Technology service providers	1.2
Telecommunications	1.2

Table 2: Retention factor

Selected	Base retention (\$)			
Retention (\$)	25,000	100,000	500,000	1000,000
25,000	**1.00**	1.16	1.34	1.47
100,000	0.87	**1.00**	1.16	1.27
500,000	0.75	0.87	**1.00**	1.10
1,000,000	0.68	0.79	0.91	**1.00**

Table 3: Increased limit factor

Coverage limit (\$)	Increased limit factor
1,000,000	1.000
2,500,000	1.865
5,000,000	2.987
10,000,000	4.786
25,000,000	8.925

Note that other carriers use similar frameworks for calculating the final premium. We refer the interested reader to Ref. [1] for a more complete overview of current insurance policies. This multiplicative formula described above constitutes the basic model used for our analysis in the next section.

Example: We complete this section by providing an example of how the final premium is calculated using the above tables. Consider a non-financial Technology Service Provider with an annual revenue \$6 M who intends to purchase an insurance policy with retention \$100,000, coverage limit \$2.5 M, and zero percent co-insurance. Moreover, this firm does not use any third-party services; it wishes to opt in for additional coverage for privacy notification expense and crisis management expense. Based on the above tables, the following factors will be used in determining the total premium for this company:

- Base premium: \$7,500; Base Retention: \$25,000
- Industry factor: 1.2 (Table 1).
- Retention factor: 0.87 (Table 2).
- Limit factor: 1.865 (Table 3).
- Third-party modifier factor: 1; Co-insurance factor: 1 (Table 4).
- Privacy notification: 0.15.
- Crisis management: 0.02.

Therefore, the premium for this service provider is calculated as follows,

$$\begin{aligned}\text{Premium} &= 7500 \times 1.2 \times 0.87 \times 1.865 \times 1 \times 1 + 7500 \times (0.15 + 0.02) \\ &= 14602.95 + 1275 = \$15,877.95.\end{aligned} \tag{1}$$

The insurance policy model and analysis

In this section, we model three portfolio alternatives available to the insurance carrier, as depicted in Figure 1: insure just the service provider and let someone else insure its customers (*Portfolio type A*), insure both the service provider and its customers (*Portfolio type B*), or insure just the service provider's customers and let someone else insure the SP (*Portfolio type C*).

In each case, the question we are interested in understanding to what extent the insurer may be able to induce the parties to reduce their risk while maximizing its own profits. We examine how these policy incentives can be used to reduce the direct and indirect risks to the parties involved. To do so, over the next few subsections we

Table 4: Co-insurance factor

Co-insurance (%)	Co-insurance factor
0	1.000
1.0	0.995
5.0	0.980
10	0.960
20	0.920
50	0.780

Downloaded from academic.oup.com/cybersecurity/article/5/1/tyz010/5601219 by guest on 18 October 2026

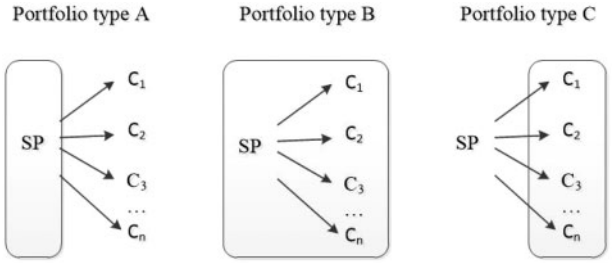


Figure 1: Three portfolio types: shaded areas indicate entities insured by an underwriter.

develop a model that formally establishes an insurance carrier's profit, as a function of the insurance policy terms as well as incentives embedded in the policy.

Base premium calculation

Consider an insurer and its prospective insureds (the applicants), which include a service provider (SP, e.g. Amazon cloud services) and its n customers. The insurer charges a base premium b_o to the service provider and base premiums b_i to its customers i, $i = 1, 2, \cdots, n$.

As described, the base premium, b_i, depends on the total assets or revenue of the insureds. The insurer then asks the applicants to fill out a questionnaire describing their information security practices. Based on the completed questionnaire, the insurer modifies the base premiums by a factor f_i, $i = 0, 1, \cdots, n$, as described in the previous section. The insured pays $b_i \cdot f_i$ up front, and the insurer pays the insured $\max\{L_i - d_i, 0\}$ after a loss incident where L_i is a random variable denoting the loss amount of agent i and d_i is its elected retention/deductible. For the analysis that follows, we ignore all the other factors unrelated to cybersecurity, as their inclusion (as additional multipliers) does not affect our model or our conclusion.

This model does not yet consider dependent risks. Specifically, insured i's premium $b_i f_i$, $i = 1, \cdots, n$, is purely a function of its own security posture. While the information security questionnaire used to generate modifier factor f_i may include questions on whether i has a third-party supplier, or whether it has proper procedures/policies in place in handling a third party, it does not directly assess the security posture of these third parties. This instead is assessed separately. We refer an interested reader to the Chubb CyberSecurity policy shown in the Supplementary Appendix.

The security incentive modifier

We now introduce an incentive factor, f'_o, for the SP and subsequently examine its impact on the SP as well as its n customers. Specifically, suppose the insurer is willing to offer the SP a discounted premium in exchange for improved security posture as follows:

- The SP has an initially assessed premium $b_o f_o$, with a security modifier factor f_o.
- The SP agrees to invest more in security such that it could now be assessed at $\tilde{f}_o = f_o - f'_o$, for some $f'_o \in [0, f_o]$, i.e., a reduction in the modifier factor.
- In return, the insurer agrees to revise the premium to $b_o \tilde{f}_o$, reflecting a discount given the SP's improved security posture. Specifically, $b_o f'_o$ is the discount the SP receives.

Note that here for simplicity of presentation, we have assumed that the insurer is able to assess, and willing to match exactly in discount the amount corresponding to the reduced risk. That is, this SP now enjoys a revised premium equal to that which it would have received had it started at a security level measured at $\tilde{f}_o$ without the incentive. In practice the two need not be equal, i.e., the SP may require more or less in premium discount incentive to reach $\tilde{f}_o$. While this does not affect our qualitative conclusions, it does raise the interesting question as to whether in practice the incentive offered is sufficient for the SP to attain the corresponding risk reduction. In other words, could the SP take the discount amount $b_o f'_o$ and use it toward hiring additional personnel or purchasing products to achieve this goal? We will give an example in the context of the distributions used in our numerical analysis in 'Numerical examples' section.

Our subsequent analysis focuses on whether a desirable operating point for the insurer is such that $f'_o > 0$, i.e., offering the incentive to the SP. Obviously, when there is no incentive, $\tilde{f}_o = f_o$, and the problem reverts to the original premium calculation.

Mapping security incentive to probability of loss

The security modifier factor f_i is tied to some underlying assumption of the probability of a cyber incident. This modifier can increase or decrease the base premium; the larger it is, the more likely is a loss event as estimated by the insurer. To the best of our understanding, by examining the rate schedules of many actual cyber-insurance policies, this factor itself is not directly tied to the magnitude of a loss; rather we believe the expected loss amount is factored into the base premium which is tied to the sector/industry and the size of the insured. The use of such a factor in the current underwriting practice would suggest that policies are risk priced in additional to being market priced (reflected in the base premium and retention). This aspect however does not affect our analysis since we only consider a single insurer.

To be concrete, let $P_o(\tilde{f}_o)$ denote the probability of a breach to the SP, which is decreasing in the security incentive factor f'_o and increasing in the overall factor $\tilde{f}_o$. Similarly, we denote by $P_i(f_i)$, $i = 1, \cdots, n$, the probability of a loss incident of customer i *unrelated* to the SP. Both $P_o()$ and $P_i()$ are assumed to be increasing and differentiable. We will assume that if a breach happens to the SP, a business interruption (BI) or similar loss event occurs to its customer with probability t, also referred to as the level or degree of dependency. Further, we will assume that a business interruption induced by SP and the loss incident unrelated to the SP are independent events.

Putting these together, the probability of a loss event occurring to customer i is given by:

$$P_{Ii}(\tilde{f}_o, f_i) = P_i(f_i) + t \cdot P_o(\tilde{f}_o) - t \cdot P_o(\tilde{f}_o) \cdot P_i(f_i), \quad i = 1, \cdots, n \quad (2)$$

where the loss includes that due to the customer itself, due to business interruption brought on by the SP's breach, or both at the same time.

The insurer's profit function

Next, we derive expressions for the insurer's profit under two portfolio options: when it insures just the service provider (Portfolio A), and then when it insures both the service provider and its customers (Portfolio B).

The insurer's profit (V_o) and expected profit ($\bar{V}_o$) from underwriting *just* the SP are defined as follows, both shown as functions of f'_o given that our focus is on this element under the insurer's control,

$$V_o(f'_o) = b_o \cdot (f_o - f'_o) - I_o \cdot (L_o - d_o)^+; \quad (3)$$

$$\bar{V}_o(f'_o) = E\{V_o(f'_o)\} = b_o \cdot (f_o - f'_o) - l_o \cdot P_o(f_o - f'_o), \quad (4)$$

where $(x)^+ = \max\{x, 0\}$, L_o is the loss random variable, and $l_o = E((L_o - d_o)^+)$. Note that I_o is a Bernoulli random variable with parameter $P_o(f_o - f'_o)$.

Downloaded from academic.oup.com/cybersecurity/article/5/1/tyz010/5601219 by guest on 18 October 2026

We will assume the customers' security factors $f_i, i = 1, \cdots, n$ are uniformly distributed over some range $[f_{min}, f_{max}]$. The insurer's profit from customer i is then given by the following, again expressed as a function of the controllable f'_o:

$$V_i(f'_o) = b_i f_i - I_i \cdot (L_i - d_i)^+; \tag{5}$$

$$\bar{V}_i(f'_o) = b_i \cdot \frac{f_{min} + f_{max}}{2} - E_{f_i}[P_{li}(f_o - f'_o, f_i)] \cdot l_i, \tag{6}$$

where L_i is the loss random variable of customer i. Again, I_i is a Bernoulli random variable with parameter $P_{li}(f_o - f'_o, f_i)$ and $l_i = E((L_i - d_i)^+)$.

If the insurer chooses to underwrite *both* the SP and its n customers then its expected total profit is given by:

$$\bar{V}_{total}(f'_o) = \bar{V}_o(f'_o) + \sum_{i=1}^{n} \bar{V}_i(f'_o); \tag{7}$$

$$\bar{V}_{max} = \max_{f'_o} \ \bar{V}_{total}(f'_o). \tag{8}$$

Analysis of the optimal incentives and carrier profits

Now that we have established expressions for the carrier's profits as a function of security incentives, we next seek to answer two questions: first, what security incentives should the carrier provide the service provider, and second, which portfolio strategy yields higher profit?

We have defined $P_o(\tilde{f}_o)$ to be an increasing function of $\tilde{f}_o$, implying that $P_o(f_o - f'_o)$ is a decreasing function of the incentive f'_o. We assume this to be a strictly convex function of f'_o, reflecting a decreasing marginal return on effort. Note that it is widely accepted to model loss probability as a function of the security investment, see e.g., [20, 26–28]. Our model here is consistent with this literature since we have assumed that the incentive factor f'_o is proportional to security effort/investment, while allowing us to highlight and express this function in terms of the carrier's controllable in this underwriting framework.

Our first result compares the optimal incentive that an insurance carrier would offer the SP when insuring just the SP (Portfolio A), and insuring both the SP and its customers (Portfolio B). That is, we compare the optimal incentive factor f_o^* that maximizes $\bar{V}_o()$, with the optimal incentive factor f_o^{**} that maximizes $\bar{V}_{total}()$.

Theorem 1. ***Under the assumption that*** $P_o(f_o - f'_o)$ ***is decreasing and strictly convex in*** f'_o, ***we have that*** $f_o^* \le f_o^{**}$, ***where*** $f_o^* = arg\ max_{f'_o} \bar{V}_o(f'_o)$ ***and*** $f_o^{**} = arg\ max_{f'_o} \bar{V}_{total}(f'_o)$. ***In other words, the underwriter offers a higher incentive to the SP when insuring all parties, compared with the incentive offered to the SP as the only insured.***

Proof: The insurer's profit of underwriting the service provider and the customers is given by:

$$\begin{aligned} \bar{V}_{total}(f'_o) &= \bar{V}_o(f'_o) + \sum_{i=1}^{n} \bar{V}_i(f'_o) \\ &= b_o \cdot (f_o - f'_o) - l_o P_o(f_o - f'_o) + \sum_{i=1}^{n} b_i \frac{f_{min} + f_{max}}{2} \\ &\quad - l_i \cdot P_o(f_o - f'_o) \cdot (t - tE[P_i(f_i)]) - l_i \cdot E[P_i(f_i)] \ . \end{aligned} \tag{9}$$

Using the first order optimality condition, we have

$$\frac{\partial \bar{V}_{total}(f'_o)}{\partial f'_o} = 0 \tag{10}$$

$$\Rightarrow f_o^{**} = \left(f_o - (P'_o)^{-1} \left(\frac{b_o}{\left[l_o + \sum_{i=1}^{n} l_i \cdot \left(t - t \cdot E(P_i(f_i)) \right) \right]} \right) \right)^+. \tag{11}$$

Similarly, we can find the optimal value f_o^* that maximizes $\bar{V}_o$:

$$\begin{aligned} &\frac{\partial \bar{V}_o}{\partial f'_o} = -b_o + l_o \cdot P'_o(f_o - f'_o) = 0 \\ &\Rightarrow \arg\max_{f'_o} \bar{V}_o(f'_o) \in \left(f_o - (P'_o)^{-1} \left(\frac{b_o}{l_o} \right) \right)^+ \\ &\Rightarrow f_o^* = \left(f_o - (P'_o)^{-1} \left(\frac{b_o}{l_o} \right) \right)^+. \end{aligned} \tag{12}$$

Because $P'_i()$ is an increasing function and $\frac{b_o}{l_o} > \frac{b_o}{\left[l_o + \sum_{i=1}^{n} l_i \cdot (t - t \cdot E(P_i(f_i))) \right]}$, we have $f_o^* \le f_o^{**}$. □

Theorem 1 suggests that if the insurer underwrites both the SP and its customers (Portfolio B), it benefits from a better state of security (induced by higher incentive to the SP) as compared to the optimal level if it only underwrites the SP (Portfolio A). Intuitively, as the SP's risk directly impacts that of its customers, when insuring both, it is in the insurer's interest to control/reduce the SP's risk so the overall, systemic risk it is exposed to is reduced. This obviously means better overall security posture for all parties. The question is whether the insurer will voluntarily choose Portfolio B over A? The next result answers this.

Corollary 1. If parameter values b_i and l_i are such that $\bar{V}_i(f_o^*) > 0$ (i.e., there is expected profit from any single policy when the SP is incentivized at the level f_o^*; this need not be true if b_i is too small and l_i too large, in which case a rational insurer would not underwrite the policy), then we also have the following:

$$\bar{V}_{total}(f_o^{**}) \underbrace{\ge}_{\text{by the optimality } f_o^{**}} \bar{V}_{total}(f_o^*) \underbrace{\ge}_{\text{by the positivity of } \bar{V}_i(f_o^*)} \bar{V}_o(f_o^*) \ . \tag{13}$$

And similarly,

$$\bar{V}_{total}(f_o^{**}) \underbrace{\ge}_{\text{by the optimality } f_o^{**}} \bar{V}_{total}(f_o^*) \underbrace{\ge}_{\text{by the positivity of } \bar{V}_i(f_o^*)} \bar{V}_i(f_o^*) \ge \bar{V}_i(0), \tag{14}$$

where the last inequality results from the fact that the risk sustained by customer i is lower when the SP is incentivized at any level $f_o^* > 0$.

The above result suggests that at the right level of incentive for the SP, the insurer enjoys greater profits by insuring both the SP and its customers (Portfolio B), relative to insuring just the SP (Portfolio A), or any subset of its customers.

Note that Theorem 1 remains valid even when the assessment is noisy. To see this, let us assume that the SP is assessed at $\tilde{f}_o = f_o - f'_o$, but the true value is $\tilde{F}_o = \tilde{f}_o + N$ where N is a zero-mean random variable. Then we have:

$$\bar{V}_o(f'_o) = b_o \cdot (f_o - f'_o) - E(P_o(f_o - f'_o + N)) \cdot l_o. \tag{15}$$

Then as long as the function $E(P_o(f_o - f'_o + N))$ is increasing and convex, the result of Theorem 1 is valid. We next show that this is indeed an increasing and convex function. For simplicity of exposition, we will denote this function as $\Pi_o(f_o - f'_o) = E(P_o(f_o - f'_o + N))$, and denote the pdf of N by $g(.)$.

$$\begin{aligned} \Pi_o(x) &= \int P_o(x + s) g(s) ds \rightarrow \\ \Pi'_o(x) &= \int P'_o(x + s) g(s) ds \underbrace{\ge}_{P_o(.) \text{ is increasing}} 0. \end{aligned} \tag{16}$$

Downloaded from academic.oup.com/cybersecurity/article/5/1/tyz010/5601219 by guest on 18 October 2026

$$\Pi_o(\lambda \cdot x + (1-\lambda)\cdot y) = \int P_o(\lambda \cdot x + (1-\lambda)\cdot y + s)g(s)ds \underbrace{\leq}_{\text{by convexity of } P_o(.)} \tag{17}$$

$$\int \lambda \cdot P_o(x+s)g(s)ds + \int (1-\lambda)\cdot P_o(y+s)g(s)ds = \lambda \Pi_o(x) + (1-\lambda)\Pi_o(y)\ . \tag{18}$$

Third-party liability

Next, we consider third-party liability. This refers to the ability of an injured party to seek redress for losses from an injurer, and is a coverage category commonly found in insurance policies. In the context of our study, this implies that if a firm suffers loss due to business interruption brought on by a breach at its SP, the firm's insurance carrier can, on the firm's behalf, seek redress from the SP's insurer. However, if the same carrier were to underwrite both the firm and the SP, such compensation would obviously not occur. In one of the few datasets that reports actual cyber-insurance claims data, NetDiligence [29] shows that 13% of all data breaches and cyber incidents can be attributed to a third party. Accordingly, we will use a parameter q to represent the probability that a loss can be attributed to an SP.

We define U as the insurer's profit when it underwrites only the SP's customers (Portfolio C). We have:

$$\begin{aligned} &U_i(f'_o) = b_i \cdot f_i - J_i \cdot (L_i - d_i)^+; \\ &\bar{U}_i(f'_o) = E[U_i(f'_o)] \\ &= b_i \cdot \frac{f_{min}+f_{max}}{2} - (E[P_i(f_i)] + (1-q)[tP_o(f_o - f'_o) - E[P_i(f_i)]tP_o(f_o - f'_o)])l_i, \end{aligned} \tag{19}$$

where J_i is a Bernoulli random variable with parameter $P_i(f_i) + (1-q)\cdot[tP_o(f_o - f'_o)\cdot(1-P_i(f_i))]$; this is the probability that a loss incident happens to customer i and *cannot* be attributed to the SP. In this case, the SP is insured by another carrier, referred to as the third-party insurer, whose profit is given by:

$$U_o(f'_o) = b_o(f_o - f'_o) - I_o \cdot (L_o - d_o)^+ - \sum_{i=1}^{n} K_i \cdot (L_i - d_i)^+; \tag{20}$$

$$\begin{aligned} \bar{U}_o(f'_o) &= E[U_o(f'_o)] \\ &= b_o \cdot (f_o - f'_o) - P_o(f_o - f'_o)\cdot l_o \\ &\quad - \sum_{i=1}^{n} q \cdot [tP_o(f_o - f'_o)]\cdot[1 - E[P_i(f_i)]]l_i, \end{aligned} \tag{21}$$

where K_i is a Bernoulli random variable with parameter $q\cdot[tP_o(f_o - f'_o)]\cdot[1-P_i(f_i)]$; this is the probability that a loss incident happens to customer i and it *can* be attributed to the third party successfully. Here, we have assumed that whenever losses can be attributed to the SP, the customer's insurer (also referred to as the primary insurer) is fully reimbursed. However, our result in Theorem 2 remains valid for partial or fractional compensation as well.

Next, we compare the insurer's profit from underwriting only the SP's customers (with the possibility of recovering losses from the SP's insurer) (Portfolio C), with its profit from underwriting both the SP and its customers (Portfolio B).

We denote the insurer's profit from underwriting only the SP's customers as $\bar{U}_{max} = \sum_{i=1}^{n} \bar{U}_i(f_o^\star)$, where $f_o^\star = \text{argmax}_{f'_o} \bar{U}_o(f'_o)$, and denote the insurer's profit from underwriting both the SP and its customers as $\bar{V}_{max}$ from Eqn. (8), where the maximum is attained at f_o^{**}.

Theorem 2. At the right level of incentive for the SP, the insurer enjoys greater profit by insuring both the SP and its customers (Portfolio B), rather than just the SP's customers (Portfolio C). That is, $\bar{V}_{max} \geq \bar{U}_{max}$, where $\bar{V}_{max} = \bar{V}_o(f_o^{**}) + \sum_{i=1}^{n} \bar{V}_i(f_o^{**})$, and $\bar{U}_{max} = \sum_{i=1}^{n} \bar{U}_i(f_o^\star)$. Moreover, given that $P_o(f_o - f'_o)$ is decreasing and convex in f'_o, we have $f_o^\star \leq f_o^{**}$, which implies that the state of security improves for both the SP and its customers when the insurer underwrites both.

The first part of the above result is rather trivial: if the primary insurer is compensated by the third-party insurer, it must therefore be profitable to underwrite the SP (otherwise, the SP would not be able to obtain a policy in the first place). Thus, the insurer of the SP's customers can only gain by insuring the SP itself.

The second part of the result is more interesting and less straightforward. The intuition is that when the insurer underwrites both the SP and its customers (Portfolio B), it is in its best interest to provide stronger incentive to the SP in an attempt to reap the multiplicative effect of risk reduction of the SP on its customers, i.e., the positive externality. In summary, by embracing the risk dependency, the insurer not only gains but also contributes to social welfare.

As in the case of Theorem 1, the result of Theorem 2 remains valid even when the SP's assessment is noisy, by following the same argument.

Summary of the findings

The findings suggested by the analysis shown in this section are summarized as follows.

- Given the choice between insuring just the SP (Portfolio A), or the SP and all its customers (Portfolio B), an insurance carrier should choose Portfolio B. The reason is that the insurer can incentivize the SP to improve its security posture in exchange for discounted premium. While this reduces the insurer's revenue from the SP, it improves the security posture of the SP and its customers, leading to fewer claims from business interruptions. Collectively, this leads to lower overall risk, higher profits for the insurer.
- Given the choice between insuring both the SP and its customers (Portfolio B), or just the SP's customers (Portfolio C) and attributing losses to the SP, an insurance carrier should choose Portfolio B.
- This is because with Portfolio C the insurer is unable to effectively induce the SP to improve its security posture, which negatively affects all of the provider's customers.
- If an insurer chooses to underwrite only the SP's customers (Portfolio C), it should incorporate the risk condition of the SP into the service provider's customers' premiums. In contrast, current practice often ignores the security posture of the SP (or any third parties) when pricing the customer's policy.

Next, we use data from an actual cyber-insurance policy, as well as one of the only sources of insurance claims data, to calibrate and substantiate our analysis through numerical examples.

Numerical examples

In this section, we examine closely a number of numerical examples that put the preceding analytical results into context. To do so, we will need to substantiate two elements of our model: the relationship between the security modifying factor, i.e., the function $P(f)$, and the loss distribution governing L. We will also use base premium and retention values found in 'Computing premiums using base rates – examples from an actual underwriter' section.

Downloaded from academic.oup.com/cybersecurity/article/5/1/tyz010/5601219 by guest on 18 October 2026

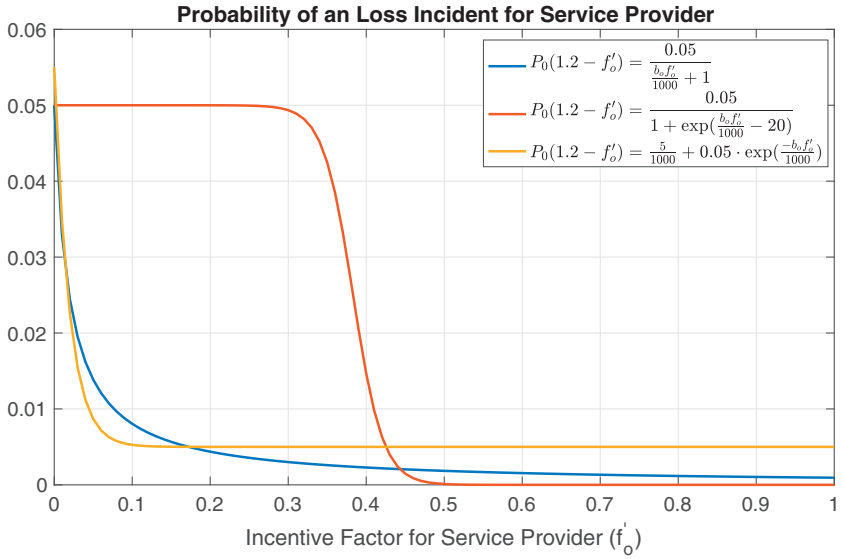


Figure 2: $P_o(1.2 - f'_o)$, the probability of a loss event to the SP.

Examples of the loss probability function

We present three examples of $P_o(f_o - f'_o)$ as a function of f'_o while fixing $f_o = 1.2$ and $b_o = 52000$; these are illustrated in Figure 2 and used later in this section to perform numerical analysis.

$$P_o(f_o - f'_o) = \frac{0.05}{\frac{b_o(1.2-(f_o-f'_o))}{1000}+1} \tag{22}$$

$$P_o(f_o - f'_o) = \frac{0.05}{\left(1+\exp\left(\frac{b_o\cdot(1.2-(f_o-f'_o))}{1000}-20\right)\right)} \tag{23}$$

$$P_o(f_o - f'_o) = \frac{5}{1000}+0.05\cdot\exp\left(-\frac{b_o\cdot(1.2-(f_o-f'_o))}{1000}\right) \tag{24}$$

The choice of these functions are somewhat arbitrary: the main intent is to capture a few families of decreasing functions with subtle yet significant differences as explained below, while noting that our conclusion and results hold more generally. More specifically:

- The loss given in Equation (22) (the blue curve) is simply a decreasing, convex function which indicates that initial effort in risk reduction results in larger marginal benefits in loss reduction, but that the loss probability will continue to decrease at a diminishing rate. This would apply to a typical firm whose initial investment (say in firewall) is very effective, after which more expensive products (e.g., intrusion detection) continue to reduce risk but at a decreasing rate.
- The loss in Equation (23) (the red curve) suggests the initial effort has to be significant enough (exceeding a threshold) to have any appreciable effect on loss reduction. Equivalently, this may be viewed as modeling a type of firms that only respond to incentives when they are substantial or when they reach a tipping point. Beyond this, the curve similarly exhibits diminishing returns. Note that this loss function is not convex but we show in the Supplementary Appendix the result of Theorem 1 holds in this case as well.
- Finally, the loss in Equation (24) (the yellow curve) illustrates a scenario where the reduction in loss initially behaves similarly to the first case, but reaches a maximum at a point beyond which no amount of effort can further reduce. This captures the situation where external factors beyond the insured's control is at significant play, contributing to a non-zero "floor" in the probability of a loss event. This could apply to the case where there is persistent susceptibility to social engineering that no amount of investment or training can completely remove; or, where the firm is simply not able to address all security challenges.

Table 5: Cost of data breach between 2016 and 2017 organized based on the breached firm's revenue

	Cases	Median ($)	Mean ($)
Nano revenue (<$50M)	52	49,000	215,297
Micro revenue ($50M–$300M)	31	88,154	487,411
Small revenue ($300M–$2B)	15	118,671	599,907
Mid revenue ($2B–$10B)	9	91,457	173,851
Large-revenue ($10B–$100B)	8	3,326,313	5,965,571

It should be noted that the above examples serve to illustrate the different ways loss probabilities may change as incentives/security investments increase. The actual values used may or may not accurately reflect reality. For instance, in reality, the scale of the loss probability could be orders of magnitude larger (0.1 instead of 0.01) or smaller (0.001 instead of 0.1). Unfortunately, there is no publicly available data that would allow us to calibrate. As already mentioned, it is unclear how these factor values were derived by an underwriter in the first place.

Examples of the loss distribution

We will use data reported in the cyber-insurance claims study by NetDiligence [29] to obtain breach loss distributions, summarized in Table 5. The "Mid Revenue" range contains somewhat unexpected small median and mean values. This appears to be an anomaly: since the sample sizes (number of cases) are small, an oversized or undersized breach can significantly throw off the average.

Example 1: a service provider and a customer with large revenue

In this example, we consider an SP and a single customer, both of large revenue (e.g., a major web hosting provider and a large corporate customer). Using the rate schedule provided in 'Computing premiums using base rates – examples from an actual underwriter' section, we will set the base premium and base retention for the SP and its customer to be $b_o = b_1 = \$52,000$ and $d_o = d_1 =$

Downloaded from academic.oup.com/cybersecurity/article/5/1/tyz010/5601219 by guest on 18 October 2026

$250,000, respectively. We consider the following loss function for the customer: $P_1(f_1) = \frac{0.05}{\frac{b_1 \cdot (1.2 - f_1)}{1000} + 1}$. Moreover, factor f_1 is uniformly distributed over $[0.6, 1.2]$ with $E(f_1) = 0.9$ and as mentioned this depends on the outcome of its information security questionnaire.

Using the NetDiligence data, we will assume that both L_o and L_1 are log-normally distributed with a mean of $5,965,571 and median $3,326,313. Moreover, as mentioned earlier NetDiligence reports that 13% of data breaches can be attributed to a third party; we will accordingly set $q = 0.13$. We will assume that the SP was assessed with $f_o = 1.2$.

We will first consider $P_o(f_o - f_o') = \frac{0.05}{\frac{52000 \cdot (1.2 - (f_o - f_o'))}{1000} + 1}$, with results shown in Figure 3. Figure 3(a) plots the optimal incentive factor in different portfolios as a function of the dependency factor t:

$$\text{Portfolio A}: \quad f_o^* = \arg\max_{f_o'} V_o(f_o'),$$
$$\text{Portfolio B}: \quad f_o^{**} = \arg\max_{f_o'} V_{total}(f_o'),$$
$$\text{Portfolio C}: \quad f_o^\star = \arg\max_{f_o'} U_o(f_o') \ .$$

Figure 3(b) illustrates the probability of a loss event to the SP and its customers at optimal incentive factor $(f_o^*, f_o^{**}, f_o^\star)$ as a function of dependency t.

These figures imply that, if the insurer underwrites only the SP (Portfolio A, blue line), t does not factor into the policy decision and thus the insurer will not offer any incentive to the SP. On the other hand, if the insurer underwrites both, then offering incentive to the SP is now in its interest, and the incentives increases as t increases (Portfolio B, orange line). Finally, if an insurer underwrites only the SP and pays the third-party compensation for its customer's loss (yellow line), the incentive factor is also increasing as a function of t but it increases slower than f_o^{**}. Figure 3(c) shows how much can be gained by taking risk dependency into account, and the higher the dependency the more the insurer gains by jointly designing contracts for both the SP and its customer.

The case $P_o(f_o - f_o') = \frac{0.05}{\left(1 + \exp\left(\frac{b_o(1.2 - (f_o - f_o'))}{1000} - 20\right)\right)}$ and $P_o(f_o - f_o') = \frac{5}{1000} + 0.05 \exp\left(-\frac{b_o(1.2 - (f_o - f_o'))}{1000}\right)$ are shown in Figure 4 and 5, respectively. We see the similar result as figure 3 in these figures as well.

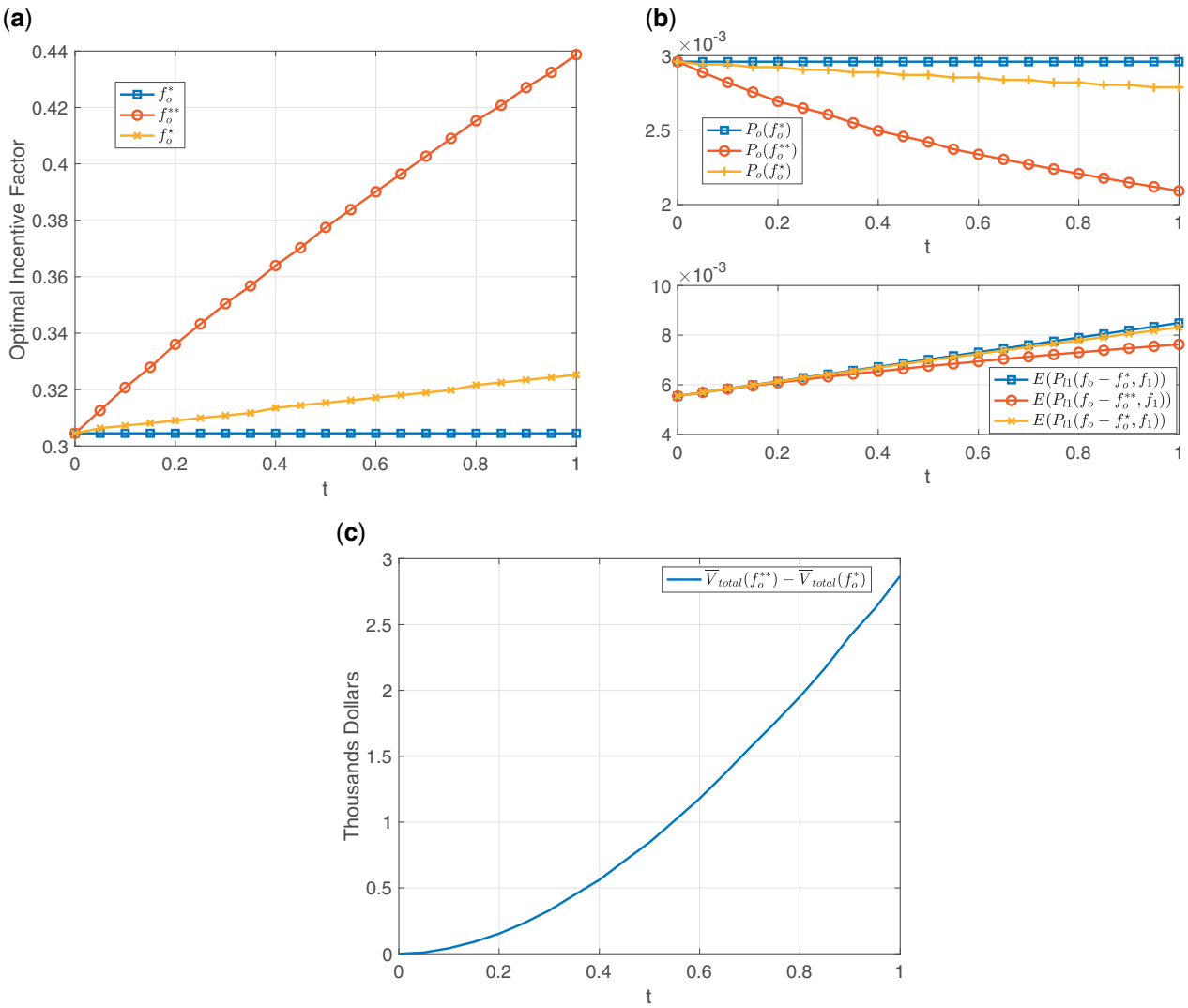


Figure 3: Optimal incentive factor and probability of a loss incident and profit gain under loss model. Optimal incentive factor as a function of t (a); Probability of a loss incident as a function of t (b); Profit gain as a function of t (c) [22].

Downloaded from academic.oup.com/cybersecurity/article/5/1/tyz010/5601219 by guest on 18 October 2026

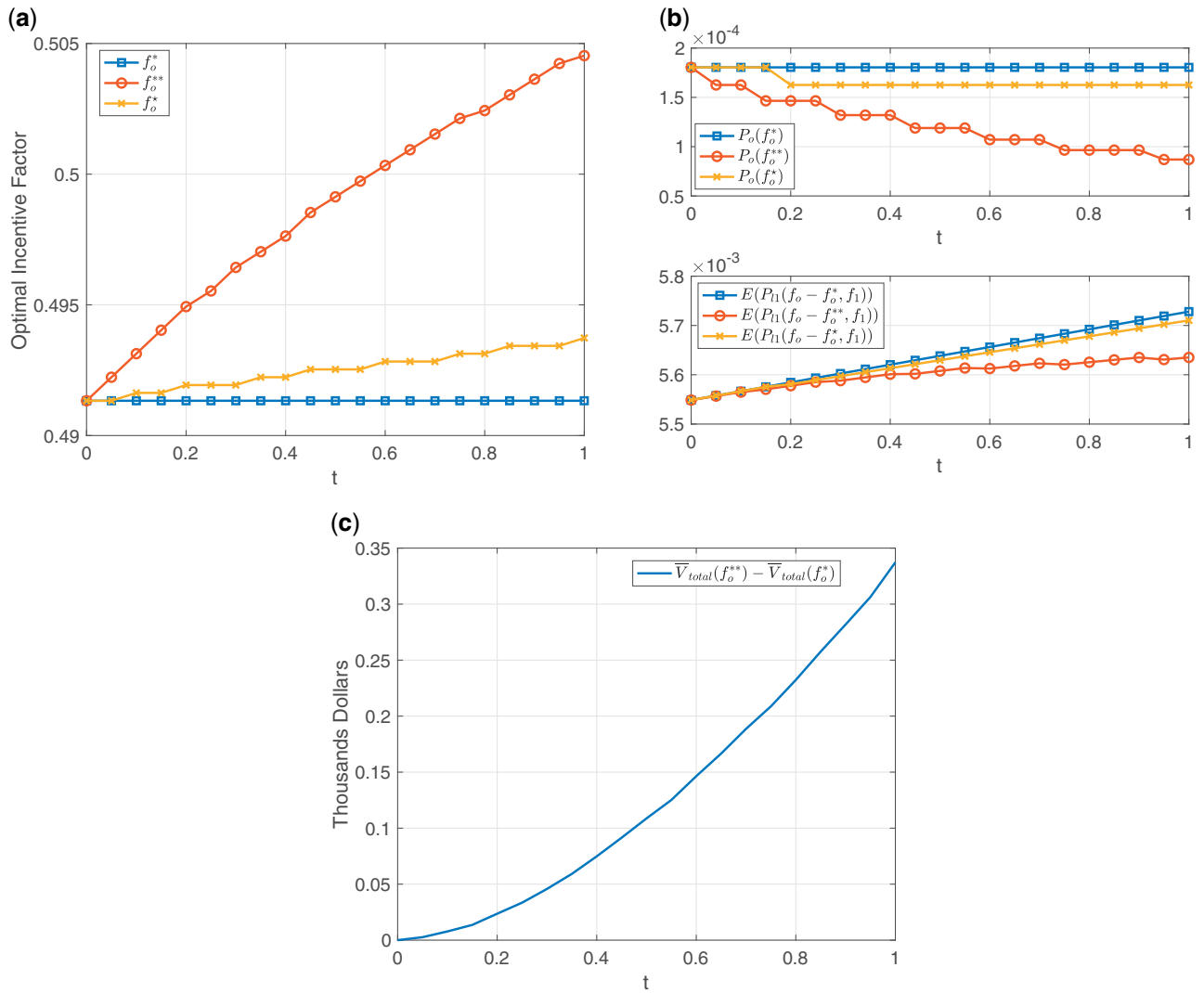


Figure 4: Optimal incentive factor and probability of a loss incident and profit gain under loss model [23]. Optimal incentive factor as a function of t (a); Probability of a loss incident as function of t (b); Profit gain as function of t (c).

Example 2: an SP and multiple customers with smaller revenue

In this example, we consider an SP and n customers with relatively small revenue and study the impact of n on the optimal policy and insurer's utility.

Again, using the rate schedule provided in 2, we will set the base rate and retention for the customers at $b_i = \$5,000$, $d_i = \$25,000$, $i = 1, \cdots, n$. The factors f_i, $i = 1, \cdots, n$ are drawn uniformly from $[0.6\ ,\ 1.2]$. Using Table 5, the loss random variable L_i, $i = 1, \cdots, n$ has a mean and median of \$599,907 and \$118,671, respectively. Similar as in the previous example, the mean and median of loss L_o are set at \$5,965,571 and \$3,326,313, respectively. We again assume that L_i follows a log-normal distribution. In addition, we set $f_o = 1.2$, $t = 0.5$, and $q = 0.13$. Compared to the previous example, in this example, we shall also examine the effect of the number of customers (n) on the optimal policy. Moreover, we consider the following loss function for customer i: $P_i(f_i) = \frac{0.05}{\frac{5000(1.2-f_i)}{1000}+1}$. The results are shown in Figure 6.

Figure 6(a) illustrates the optimal incentive factors $f_o^*, f_o^{**}, f_o^\star$ as a function of n. This plot implies that as the number of customers increases, the SP's insurer would incentivize the SP more in both portfolio B and C. The reasons behind this is obvious: as the risk spillover impacts more customers, the more the SP can reduce its risk, the greater the benefit to the SP's insurer (e.g., fewer business interruptions). Specifically, given that a breach occurred to the SP, the probability of no upstream business interruption is given by $1-(1-t)^n$, which an increasing function of n. Thus, it is in the insurer's interest to reduce the likelihood of loss on the part of the SP. As a result, both f_o^{**} and $f_o^\star$ are increasing in n, while f_o^* is independent of n as it maximizes only $\bar{V}_o$ without considering dependency. Figure 6(b) implies that if the insurer does not gain by underwriting the customers and attributing all or a part of the loss to the SP as compared to the profit by underwriting all of them; we see in some cases, the third party's insurer has negative expected profit, in which case a policy is not viable.

Figures 7 and 8 show similar results for the other two loss functions $P_o(f_o - f_o') = \frac{0.05}{\left(1+\exp\left(\frac{b_o(1.2-(f_o-f_o'))}{1000}-20\right)\right)}$ and $P_o(f_o - f_o') = \frac{5}{1000} + 0.05 \cdot \exp\left(-\frac{b_o \cdot (1.2-(f_o-f_o'))}{1000}\right)$.

We now comment on Figures 6(c), 7(c), and 8(c), which illustrate the insurer's payout distribution when the SP has $n = 10$ customers. All three show that portfolios B and C are faced with the same

Downloaded from academic.oup.com/cybersecurity/article/5/1/tyz010/5601219 by guest on 18 October 2026

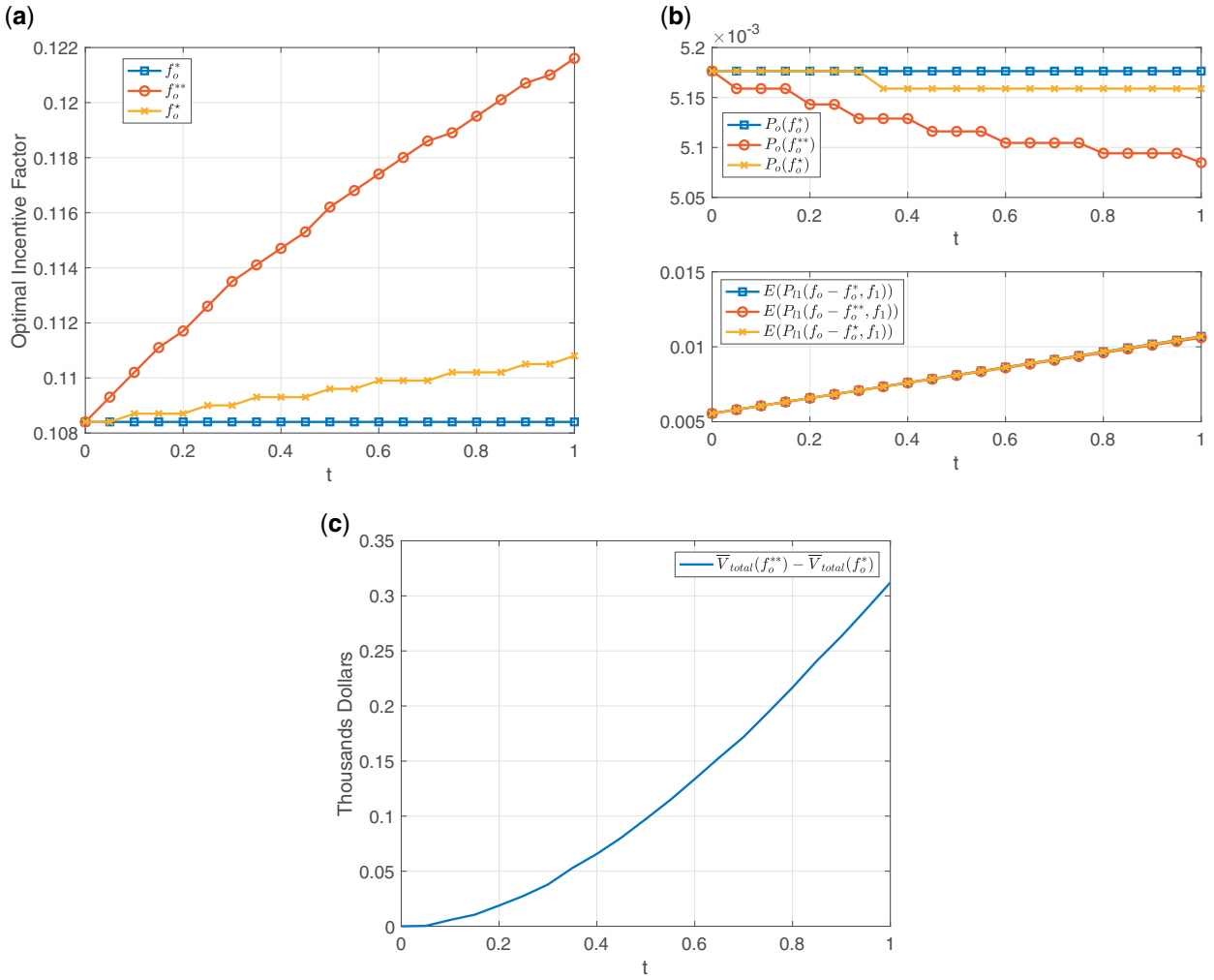


Figure 5: Optimal incentive factor and probability of a loss incident and profit gain under loss model [24]. Optimal incentive factor as a function of t (a). Probability of a loss incident as a function of t (b); Profit gain as a function of t (c).

payout distributions regardless of the loss model being used. This is in contrast to the earlier comparison when there is only a single customer. This is because more customers leads the insurer to increase its incentive for the SP in order to lower its risk and its customers' risk; this is absent under portfolio C. As a result of this, the two portfolios actually experience the same amount of risk in payout; so again in this case portfolio B is uniformly better than C.

Discussions

We now discussion further three aspects of the model studied in this article.

Is the premium discount sufficient?

Consider a non-financial technology service provider firm with annual revenue between \$5 M and \$10 M. In this case, the base premium $b_o = \$7,500$. We will assume the firm is assessed with $f_o = 1.2$. Now assume that the insurer sets the incentive factor f'_o to be 0.35. Therefore, the firm pays $b_o \cdot (f_o - f'_o) = \$6375$ as the premium, after receiving $b_o \cdot f'_o = \$2625$ in discount. Using salary surveys such as Ref. [30], consider an IT security personnel with a bachelor's degree, 5 years of experience, and commands annual salary $W = \$85K$ for $N = 50$ working weeks. The premium discount the firm receives can be translated into a fraction of this person's compensation:

$$\frac{b_o \cdot f'_o}{W} \times N = \frac{\$2625}{\$85000} \times 50 = 1.5 \text{ weeks.} \quad (25)$$

Therefore, the incentive provided by the underwriter is just enough to hire an experienced person for 10 days. It is debatable whether this amount of investment in security is adequate to reduce the firm's cyber risk (by 10^{-9} according to Model (23), or by 0.05 according to Model (24), by setting $b_o = \$7,500$ in each, respectively). A potential mismatch between what this analysis suggests and reality may be attributed to two factors. First, as already mentioned, the loss values shown in Figure 2 could be orders of magnitude different from reality; in other words, if the risk reduction is from a breach probability of 0.1–0.07%, then perhaps 10 days' worth of work (say in deploying software patches) is sufficient. Second, it may also be argued that the current levels of base premium is inconsistent with the underlying cyber risk (and what it takes to reduce the risk) to begin with.

Social welfare

Our study so far has focused on whether it is in the interest of an underwriter to insure risk-dependent insureds, and if so how best to do so. We now turn to the issue of social welfare, i.e., whether by embracing risk

Downloaded from academic.oup.com/cybersecurity/article/5/1/tyz010/5601219 by guest on 18 October 2026

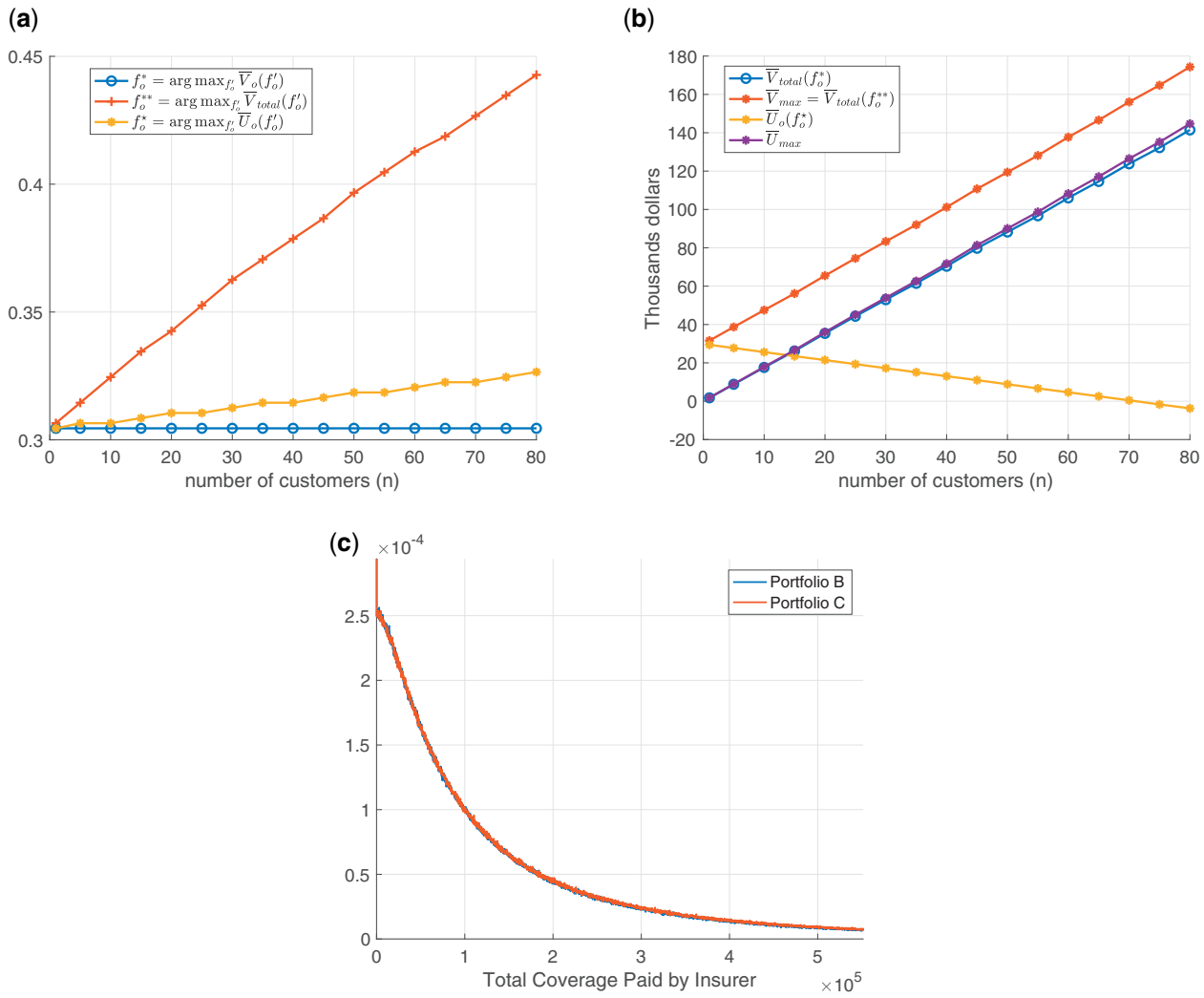


Figure 6: Optimal incentive factor and insurer's profit and pdf of the coverage paid by insurer under loss model [22]. Optimal incentive factor as a function of *n*. Optimal incentive factor is increasing in *n* (a); Insurer's profit as a function of *n*. The insurer does not gain by underwriting the SP's customers and attributing the loss to the SP (b); Probability Distribution Function (pdf) of the amount paid out by the insurer in different scenarios (c).

dependency the underwriter can also help improve the total utility. We have shown that underwriting both SP and its customers and giving SP more discount on premium improves the insurer profit and decreases the probability of data breach. As a consequence of the latter, the utility of the insureds improves; thus underwriting both SP and its customers improves the social welfare (total utility) in general. Let $C_o(f_o')$ and $C_i(f_o')$ be the total expected cost paid by the SP and its customer, respectively. We have,

$$\begin{aligned} C_o(f_o') &= \underbrace{b_o \cdot f_o}_{\text{Premium}} + \underbrace{E\{D_o\} \cdot P_o(f_o - f_o')}_{\text{Expcted uncovered loss}} \\ C_i(f_o') &= \underbrace{b_i \cdot f_i}_{\text{premium}} + \underbrace{E\{D_i\} \cdot P_{li}(f_o - f_o')}_{\text{Expected uncovered loss}}, \end{aligned} \tag{26}$$

where $D_i = \begin{cases} L_i \text{ if } L_i \leq d_i \\ d_i \text{ o.w} \end{cases}$ is the amount of deductible that insured i pays. Note that we do not consider discount $b_o \cdot f_o'$ in the SP's costs because this is assumed to be used toward its security investment. We define social welfare $SW(f_o')$ to be the insurer's profit less its costs:

$$SW(f_o') = V_{total}(f_o') - C_o(f_o') - \sum_{i=1}^{n} C_i(f_o') \tag{27}$$

Below we use an example similar to that provided in 'Example 1: a service provider and a customer with large revenue' section to illustrate the impact of insurance policy on social welfare.

Consider an SP and a single customer, and assume that both have a large annual revenue ($10B–$100B), with a base rate $b_o = b_1 = \$52,000$ and base retention $d_o = d_1 = \$250,000$. We assume that $f_o = 1.2, f_1 = 1$ and $P_o(f) = P_1(f) = \frac{0.05}{1+\frac{b_o(1.2-f)}{1000}}$ and $t = 0.5$. Based on Table 5, we assume both L_o and L_1 have log-normal distribution with mean $5,965,571 and median $3,326,313.

We now compare two cases. In the first case, the insurer ignores the risk dependency and attempts to separately maximize its profit from the SP and its customer, respectively. In the second case, the insurer jointly optimizes the two policies.

In the first case, the insurer obtains the discount to the SP as follows:

$$\begin{aligned} l_o = l_1 &= E((L_o - d_o)^+) = \$5,715,600 \\ \bar{V}_o(f_o') &= b_o \cdot (f_o - f_o') - l_o P_o(f_o - f_o') \Rightarrow f_o^* = 0.3057 \end{aligned} \tag{28}$$

The insurer's profit and the insureds' costs are as follows:

- Insurer's total expected revenue:

Downloaded from academic.oup.com/cybersecurity/article/5/1/tyz010/5601219 by guest on 18 October 2026

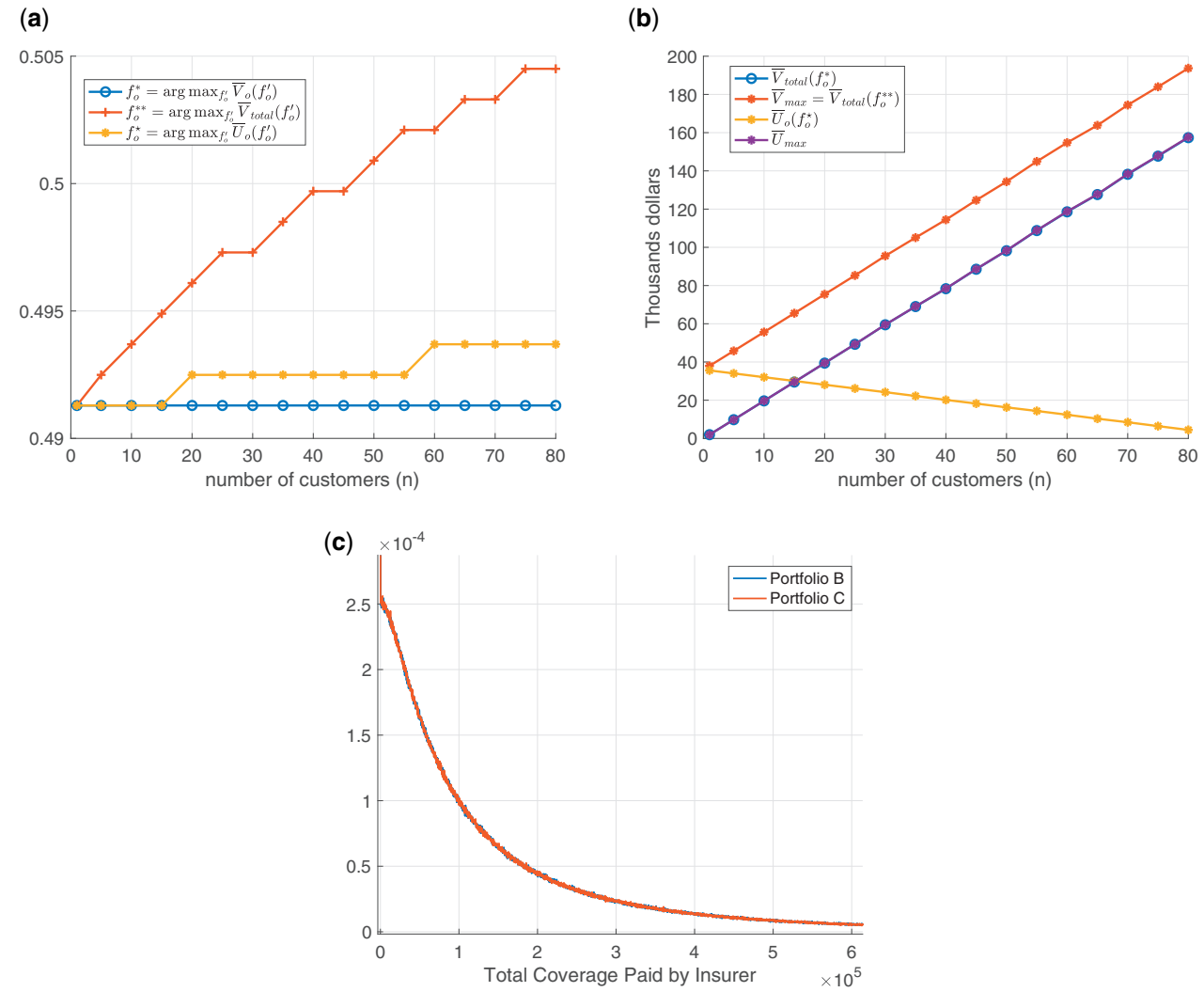


Figure 7: Optimal incentive factor and insurer's profit and pdf of the coverage paid by insurer under loss model [23]. Optimal incentive factor as a function of *n*. Optimal incentive factor is increasing in *n* (a); Insurer's profit as a function of *n*. The insurer does not gain by underwriting the SP's customers and attributing the loss to the SP (b); Probability Distribution Function (pdf) of the amount paid out by the insurer in different scenarios (c).

$$V_{total}(f_o^*) = b_o \cdot (f_o - f_o^*) - l_o P_o(f_o - f_o^*) + b_1 \cdot f_1 - P_{l1}(f_o - f_o^*) l_1$$
$$= 52000 \times (1.2 - 0.3057) - 5715600 \times 0.003 + 52000$$
$$-5715600 \times 0.0059 = \$47,635$$

- SP's expected cost:

$$C_o(f_o^*) = b_o \cdot f_o^* + E\{D_o\} P_o(f_o - f_o^*)$$
$$= +52000 \times 1.2 + 28753 \times 0.003 = \$62,486$$

- SP's customer's expected cost:

$$C_1(f_o^*) = b_1 \cdot f_1 + E\{D_1\} \cdot P_{l1}(f_o - f_o^*)$$
$$= 52000 \times 1 + 28753 \times 0.0059 = \$52,170$$

- Total utility/Social Welfare (revenue less cost):

$$SW(f_o^*) = V_{total}(f_o^*) - C_o(f_o^*) - C_1(f_o^*)$$
$$= \$47,635 - \$62,486 - \$52,170 = -\$67021$$

In the second case, the insurer jointly maximizes the profit from the SP and its customer. It obtains the optimal incentive factor as follows:

$$\bar{V}_{total}(f_o') = b_o \cdot (f_o - f_o') - l_o P_o(f_o - f_o') + b_1 \cdot f_1 - P_{l1}(f_o - f_o') l_1$$
$$\Rightarrow f_o^{**} = 0.3785$$

The insurer's profit and the insureds' costs are given by:

- Insurer's total expected revenue:

$$V_{total}(f_o^{**}) = b_o \cdot (f_o - f_o^{**}) - l_o P_o(f_o - f_o^{**}) + b_1 \cdot f_1 - P_{l1}(f_o - f_o^{**}) l_1$$
$$= 52000 \times (1.2 - 0.3785) - 5715600 \times 0.0024 + 52000$$
$$-5715600 \times 0.0056 = \$48,993$$

- SP's expected cost:

$$C_o(f_o^{**}) = b_o \cdot f_o^{**} + E\{D_o\} P_o(f_o - f_o^{**})$$
$$= 52000 \times 1.2 + 28753 \times 0.0024 = \$62,469$$

- SP's customer expected cost:

$$C_1(f_o^{**}) = b_1 \cdot f_1 + E\{D_1\} \cdot P_{l1}(f_o - f_o^{**})$$
$$= 52000 \times 1 + 28753 \times 0.0056 = \$52,161$$

- Total utility/Social Welfare (revenue less cost):

$$SW(f_o^{**}) = V_{total}(f_o^{**}) - C_o(f_o^{**}) - C_1(f_o^{**})$$
$$= \$48,993 - \$62469 - \$52161 = -\$65,637$$

We see that the total utility or social welfare is higher in the second case, when the insurer takes risk dependency into account and jointly optimizes the two policies. It is interesting to note that the

Downloaded from academic.oup.com/cybersecurity/article/5/1/tyz010/5601219 by guest on 18 October 2026

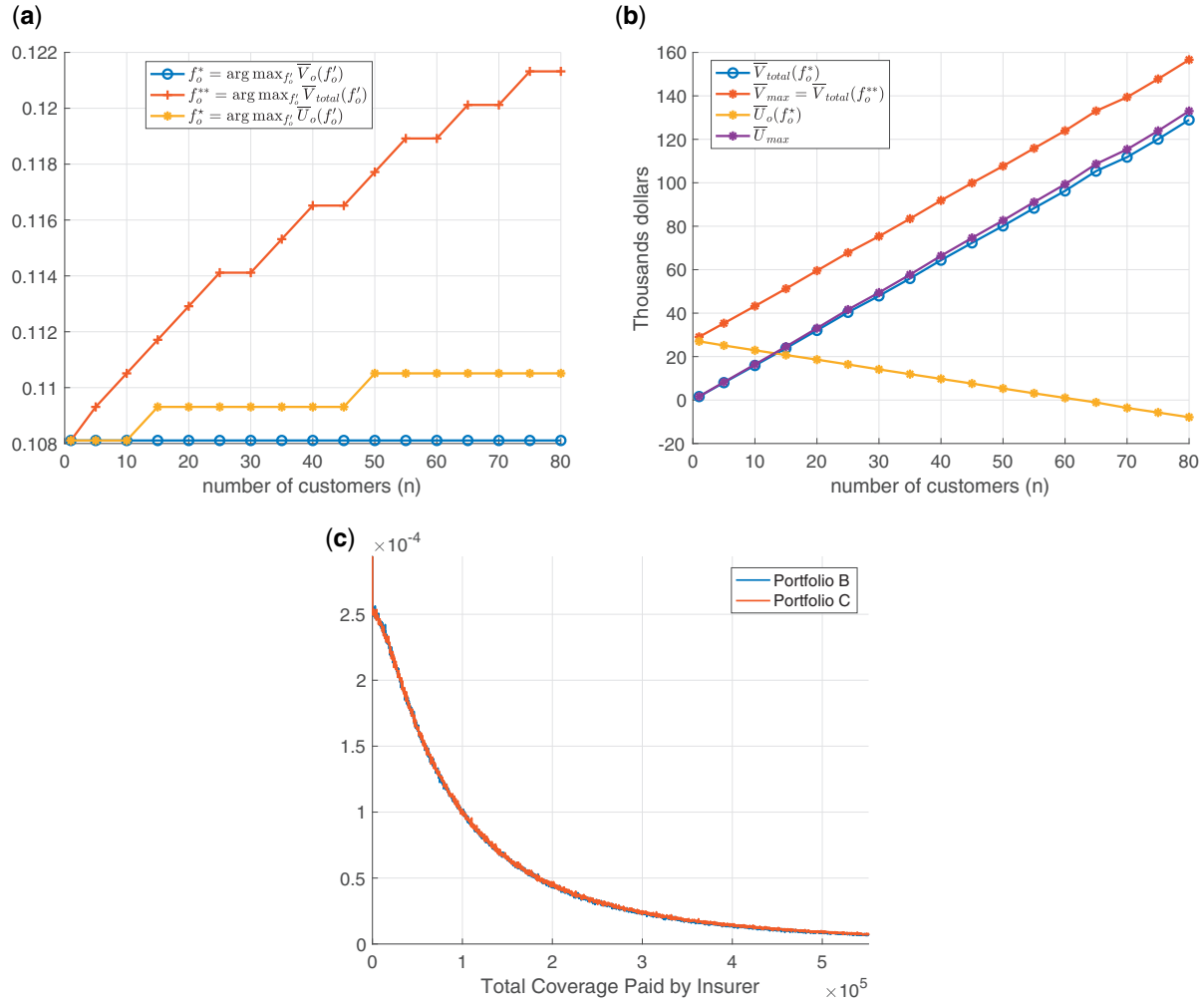


Figure 8: Optimal incentive factor and insurer's profit and pdf of the coverage paid by insurer under loss model [24]. Optimal incentive factor as function of *n*. Optimal incentive factor is increasing in *n* (a); Insurer's profit as function of *n*. The insurer does not gain by underwriting the SP's customers and attributing the loss to the SP (b); Probability Distribution Function (pdf) of the amount paid out by the insurer in different scenarios (c).

values used in this example lead to negative social welfare, i.e., the total cost born by the insureds exceeds the total profit made by the insurer. The negative total utility is a reflection of the damage inflicted by attackers behind data breaches.

Modeling third-party liability

We have assumed that the probability that the insurer can attribute a part of the loss to the third party is a constant (q) and is independent of P_o and P_i and t. An alternative model is to find probability q using P_o, P_i, and t. Let q_i be the probability that the insurer of insured i can attribute a part of the loss to its third party. Moreover, define events A_i and B_i as follows:

- A_i: a business interruption occurs to insured i due to a data breach/loss incident on the SP's side.
- B_i: a loss incident occurs to insured i.

We then have:

$$\begin{aligned} &Pr\{A_i \cap B_i\} = P_o(f_o - f_o') \cdot (1 - P_i(f_i)) \\ &P\{B_i\} = P_{li}(f_o - f_o', f_i) = P_i(f_i) + t \cdot P_o(f_o - f_o') - t \cdot P_o(f_o - f_o') \cdot P_i(f_i) \\ &q_i = Pr\{A_i|B_i\} = \frac{Pr\{A_i \cap B_i\}}{Pr\{B_i\}} = \frac{P_o(f_o - f_o') \cdot (1 - P_i(f_i))}{P_i(f_i) + t \cdot P_o(f_o - f_o') - t \cdot P_o(f_o - f_o') \cdot P_i(f_i)} \end{aligned} \tag{29}$$

The above equation implies the assumption that the insurer is always able to attribute the loss of insured i to the SP if the latter is the cause of the loss. Under this assumption, Equations (19) and (20) can be written as follows:

$$\bar{U}_i(f_o') = b_i \cdot \frac{f_{min} + f_{max}}{2} - E[P_i(f_i)] \cdot l_i. \tag{30}$$

$$\bar{U}_o(f_o') = b_o \cdot (f_o - f_o') - P_o(f_o - f_o') \cdot \left[l_o + t \cdot \sum_{i=1}^{n} (1 - E[P_i(f_i)]) \cdot l_i \right]. \tag{31}$$

These two equations are equivalent to Equation (19) and (20), respectively, by setting $q = 1$ in (19) and (20). Therefore, all the theorems continue to hold for $q_i = Pr\{A_i|B_i\}$.

Note that the third-party liability $t \cdot \sum_{i=1}^{n} (1 - E[P_i(f_i)]) \cdot l_i$ may be large, in which case b_o would also be large, for otherwise insuring SP alone is not profitable for the insurer. If insuring the SP alone is not viable due to high third-party liability, then neither portfolio A nor C is viable, and portfolio B becomes the only choice.

Non-monopolistic insurer

Our study has assumed a monopolistic insurer. The modeling choice is aimed at focusing rather singularly on the issue of risk dependency

Downloaded from academic.oup.com/cybersecurity/article/5/1/tyz010/5601219 by guest on 18 October 2026

without the interference of competition. Without monopoly the insurer will have to consider giving up its profit, but it does not change the main message of the study. Our analysis simply points to the fact that if the insurer recognizes the risk dependency among the insureds, then with the right incentive it can extract more profit; without monopoly it might have to give up all of this profit. Nonetheless, if there is competition, which often drives profit down to zero depending on the model, it may not be in the interest of the insurer to recognize this risk dependency or incentivize the SP. On the other hand, if one insurer is competing with another who is ignorant of the risk dependency among its prospective clients, then the first insurer now has an advantage in recognizing this and can effectively lower its cost of providing insurance and be able to offer more competitive contracts (with lower premium, i.e., returning a share of the profit to the insureds).

Conclusion

In this article, we applied a principal-agent modeling approach to understanding how an insurance carrier can best manage its portfolio risk of cyber-insurance policies, given interdependent risks across its policy holders. We calibrate our model using a common base rate approach to pricing premiums, and incorporate actual field data. We believe our results are significant because they suggest an alternative and preferred decision strategy for the carrier.

First, we found that insuring interdependent agents (an SP and its customer, Portfolio B) can lead to higher profit, compared with not insuring them simultaneously, the reason being that the insurer can incentivize the SP to increase its security level by offering a discount on its premium. When the SP provides more secure services for its customers, the chance of business interruption for the customers decreases, and the insurer's profit improves. In other words, receiving premiums from all interdependent agents and paying less in coverage due to improved security drives the profit opportunity not present when insuring interdependent agents.

In addition, we considered a scenario where the insurer underwrites only the SP's customers (Portfolio C) and is able to attribute a part of the loss to the SP and receive compensation from SP's insurer due to the third-party liability. In this case, the insurer's profit decreases compared with the scenario of insuring both the SP and its customers (Portfolio B). The reason is that the insurer loses the SP's premium and the insurer cannot incentivize the SP to decrease the chance of business interruption for SP's customers. These results refute conventional wisdom that insurers should avoid insuring interdependent agents.

Finally, we validate our results and theorems by providing numerical examples using real data. We showed the effect of interdependency (t) on the insurer's decision. As the SP and its customers become more interdependent, the insurer must incentivize the SP more in order to use the profit opportunity.

In conclusion, we believe that these results will help insurers and reinsurers better understand and manage systemic risk, while also demonstrating to policy makers how market-based insurance can improve social welfare.

On future direction is various sensitivity analysis of incentive decisions made by an insurer, such as those derived in this article, against the actual costs of obtaining accurate information that enables the decisions, including the cost of performing security assessment/audit or continued monitoring to ensure actions by an insured commensurate with the discount it received.

Supplementary Data

Supplementary data is available at *Journal of Cybersecurity* online.

Funding

This work was supported by the Air Force Research Laboratory and Department of Homeland Security (DHS) Office of S&T under [agreement number FA8750-18-2-0011]. The U.S. Government is authorized to reproduce and distribute reprints for Governmental purposes notwithstanding any copyright notation thereon. The views and conclusions contained herein are those of the authors and should not be interpreted as necessarily representing the official policies or endorsements, either expressed or implied, of the Air Force Research Laboratory and Department of Homeland Security (DHS) Office of S&T or the U.S. Government. This work was also supported by the National Science Foundation (NSF) under [grant numbers CNS-1422211, CNS-1616575, CNS-1739517].

References

1. Romanosky S, Ablon L, Kuehn A *et al*. Content analysis of cyber insurance policies: how do carriers price cyber risk? *Journal of Cybersecurity* 2019;**5**:tyz002.
2. Vakilinia I, Badsha S, Sengupta S. Crowdfunding the insurance of a cyber-product using blockchain. In: *Ubiquitous Computing, Electronics and Mobile Communication Conference (UEM-CON)*, 2018.
3. Tosh DK, Vakilinia I, Shetty S *et al*. Three layer game theoretic decision framework for cyber-investment and cyber-insurance. In: Rass S, An B, Kiekintveld C *et al*. (eds), *Decision and Game Theory for Security*. Springer International Publishing, 2017, 519–32.
4. Hoang DT, Niyato D, Wang P. Optimal cost-based cyber insurance policy management for mobile services. In: *2017 IEEE 86th Vehicular Technology Conference (VTC-Fall)*, Toronto, ON, Canada, Sept. 2017, Piscataway, NJ: IEEE, 1–5.
5. Böhme R, Schwartz G. Modeling cyber-insurance: towards a unifying framework. In: *Proceedings of the Workshop on the Economics of Information Security (WEIS), Cambridge, MA, USA* 2010.
6. Pal R, Golubchik L, Psounis K *et al*. On a way to improve cyber-insurer profits when a security vendor becomes the cyber-insurer. In: *2013 IFIP Networking Conference, Brooklyn, NY, USA*, May 2013, Piscataway, NJ: IEEE, 1–9.
7. Vakilinia I, Sengupta S. A coalitional cyber-insurance framework for a common platform. *IEEE Transactions on Information Forensics and Security*, 2018.
8. Understanding Systemic Cyber Risk. In: *Global Agenda Council on Risk and Resilience, World Economic Forum*, Oct. 2016. http://www3.weforum.org/docs/White_Paper_GAC_Cyber_Resilience_VERSION_2.pdf (1 October 2016, date last accessed).
9. Miura-Ko RA, Yolken B, Bambos N *et al*. Security investment games of interdependent organizations. In: *Proceedings of 46th Annual Allerton Conference on Communication, Control, and Computing, Urbana-Champaign, IL, USA*, Piscataway, NJ: IEEE, 2008, 252–60.
10. Johnson B, Grossklags J, Christin N *et al*. Are security experts useful? Bayesian Nash equilibria for network security games with limited information. In: *European Symposium on Research in Computer Security*. Springer, 2010, 588–606.
11. Johnson B, Grossklags J, Christin N *et al*. Uncertainty in interdependent security games. In: *International Conference on Decision and Game Theory for Security*, Berlin, Heidelberg: Springer, 2010, 234–44.
12. Farhadi F, Tavafoghi H, Teneketzis D *et al*. A dynamic incentive mechanism for security in networks of interdependent agents. In: *Game Theory for Networks: 7th International EAI Conference, GameNets 2017 Knoxville, TN, USA, May 9, 2017, Proceedings*. Cham: Springer International Publishing, 2017, 86–96.
13. Hasheminasab SA, Tork Ladani B. Security investment in contagious networks. *Risk Analysis*. doi: 10.1111/risa.12966. eprint: https://onlinelibrary.wiley.com/doi/pdf/10.1111/risa.12966. URL: https://onlinelibrary.wiley.com/doi/abs/10.1111/risa.12966.
14. Ezhei M. Tork Ladani, B. Interdependency analysis in security investment against strategic attacks. *Information Systems Frontiers* Apr. 25, 2018. DOI: 10.1007/s10796- 018-9845-8. URL: https://doi.org/10.1007/s10796-018-9845-8.

Downloaded from academic.oup.com/cybersecurity/article/5/1/tyz010/5601219 by guest on 18 October 2026

15. La RJ. Effects of degree correlations in interdependent security: good or bad? *IEEE/ACM Transactions on Networking* 2017;**25**:2484–97.
16. Laszka A, Schwartz G. Becoming cybercriminals: incentives in networks with interdependent security. In: Zhu Q, Alpcan T, Panaousis E *et al*. (eds) *Decision and Game Theory for Security: 7th International Conference, GameSec 2016, New York, NY, USA, November 2–4, 2016, Proceedings*. Cham: Springer International Publishing, 2016, 349–69.
17. Shetty S, McShane M, Zhang L *et al*. Reducing informational disadvantages to improve cyber risk management. *The Geneva Papers on Risk and Insurance - Issues and Practice* Feb. 6, 2018; ISSN: 1468–0440. DOI: 10.1057/s41288-018-0078-3. URL: https://doi.org/10.1057/s41288-018-0078-3.
18. Kunreuther H, Heal G. Interdependent security. *J. Risk Uncertainty* 2003; **26**:231–49.
19. Strickland J. *10 Worst Computer Viruses of All Time*. https://computer.howstuffworks.com/worst-computer-viruses.htm/printable/.
20. Lelarge M. Coordination in network security games: a monotone comparative statics approach. *IEEE J. Select Areas Commun* 2012;**30**:2210–2219.
21. Zhao X, Xue L, Whinston AB. Managing interdependent information security risks: cyberinsurance, managed security services, and risk pooling arrangements. *J Manage Inform Syst* 2013;**30**:123–52.
22. La RJ. Interdependent security with strategic agents and cascades of infection. *IEEE/ACM Trans Networking* 2016;**24**:1378–1391.
23. Ogut H, Raghunathan S, Menon N. Cyber security risk management: public policy implications of correlated risk, imperfect ability to prove loss, and observability of self protection. *Risk Analysis* 2010;**31**:497–512.
24. Khalili MM, Naghizadeh P, Liu M. Designing cyber insurance policies: the role of pre-screening and security interdependence. *IEEE Trans. Inform. Forensics Security* 2018;**13**:2226–39.
25. Khalili MM, Naghizadeh P, Liu M. Embracing risk dependency in designing cyber-insurance contracts. In: *Proceedings of 55th Annual Allerton Conference on Communication, Control, and Computing, Urbana-Champaign, IL, USA*, Piscataway, NJ: IEEE, 2017.
26. Jiang L, Anantharam V, Walrand J. How bad are selfish investments in network security? *IEEE/ACM Trans. Networking* 2011;**19**:549–60.
27. Massacci F, Swierzbinski J, Williams J. Cyberinsurance and public policy: self-protection and insurance with endogenous adversaries, the Workshop on the Economics of Information Security (WEIS), San Diego, CA, USA, 2017.
28. Pal R, Golubchik L, Psounis K *et al*. Security pricing as enabler of cyber-insurance a first look at differentiated pricing markets. *IEEE Trans Depend Secure Comp* 2017;99:1–1.
29. Evelsizer S, Netdiligence Eaton B. 2016 Cyber claims study. 2016. URL: https://netdiligence. com/wp-content/uploads/2016/10/P02 NetDiligence-2016-Cyber-Claims-Study-ONLINE.pdf (8 May 2017, date last accessed).
30. *Cybersecurity Professional Trends: A SANS Survey*. http://bit.ly/2rulxon (8 May 2014, date last accessed).

Downloaded from academic.oup.com/cybersecurity/article/5/1/tyz010/5601219 by guest on 18 October 2026

Appendix

A.1. Proof of Theorem 3.2

Theorem 3.2. Notice that $\bar{U}_o(f'_o) + \sum_{i=1}^{n} \bar{U}_i(f'_o) = \bar{V}_o(f'_o) + \sum_{i=1}^{n} \bar{V}_i(f'_o) = \bar{V}_{total}(f'_o)$. We assume that $\bar{U}_o(f_o^*) \geq 0$, otherwise no insurer underwrites the SP. By the optimality of f_o^{**} for $\bar{V}_{total}(f'_o)$ we have,

$$\begin{aligned}\bar{V}_{max} &= \bar{V}_{total}(f_o^{**}) \geq \bar{V}_{total}(f_o^*) \\ &= \bar{U}_o(f_o^*) + \sum_{i=1}^{n} \bar{U}_i(f_o^*) \geq \sum_{i=1}^{n} \bar{U}_i(f_o^*) = \bar{U}_{max}\end{aligned} \tag{32}$$

Moreover, similar to the proof of theorem 3.1, by the first order condition we can show that,

$$f_o^* = \left(f_o - (P'_o)^{-1} \left(\frac{b_o}{\left[l_o + q \cdot \sum_{i=1}^{n} l_i \cdot \left(t - t \cdot E(P_i(f_i)) \right) \right]} \right) \right)^+ \tag{33}$$

Also, from the proof of theorem 3.1, we have,

$$f_o^{**} = \left(f_o - (P'_o)^{-1} \left(\frac{b_o}{\left[l_o + \sum_{i=1}^{n} l_i \cdot \left(t - t \cdot E(P_i(f_i)) \right) \right]} \right) \right)^+ \tag{34}$$

Because $P'_i(.)$ is an increasing function and $\frac{b_0}{\left[l_0 + q \cdot \sum_{i=1}^{n} l_i \cdot \left(t - t \cdot E(P_i(f_i)) \right) \right]} > \frac{b_0}{\left[l_0 + \sum_{i=1}^{n} l_i \cdot \left(t - t \cdot E(P_i(f_i)) \right) \right]}$, we have $f_o^* \leqslant f_o^{**}$. □

A.2. Examples of the Loss Probability Function and Optimal Incentive Factors

Let's assume that $P_i(f_i) = \frac{q_i}{\frac{b_i \cdot (a_i - f_i)}{r_i} + 1}$, where q_i, a_i, r_i are constants and $q_i < 1$ and $a_i > f_{max}$. Then we have,

$$E\{P_i(f_i)\} = \frac{q_i \cdot r_i}{b_i \cdot (f_{max} - f_{min})} \ln \frac{b_i \cdot (a_i - f_{min}) + r_i}{b_i (a_i - f_{max}) + r_i} \tag{35}$$

Now we find f_o^* and f_o^{**} for the following examples,

- $P_o(f_o - f'_o) = \frac{p}{\frac{b_o \cdot (a - (f_o - f'_o))}{r} + 1}$, where p, a, r are constant.

  The optimal incentive factor f_o^* is given by,

$$f_o^* = \left(f_o - a + \frac{r}{b_o} \left(\sqrt{\frac{p \cdot l_o}{r}} - 1 \right) \right)^+ \tag{36}$$

  Moreover, we can calculate f_o^{**} as follows,

$$f_o^{**} = \left(f_o - a + \frac{r}{b_o} \left(\sqrt{\frac{p \cdot \left[l_o + \sum_{i=1}^{n} l_i \cdot \left(t - t \cdot E(p_i(f_i)) \right) \right]}{r}} - 1 \right) \right)^+ \tag{37}$$

  Notice that $f_o^{**} \geq f_o^*$.

- $p_o(f_o - f'_o) = \frac{p}{\left(1 + \exp\left(\frac{b_o \cdot (a - (f_o - f'_o))}{r} \right) \right)}$ where p, a, r are constants. Notice that this faction is not convex but we will show that $f_o^{**} \geq f_o^*$ in this case as well.

  The optimal incentive factor f_o^* is given by,

  - If $\frac{p \cdot l_o}{r} < 4$, then $f_o^* = 0$
  - If $\frac{p \cdot l_o}{r} > 4$ and $\frac{\frac{p \cdot l_o}{r} - 2 + \sqrt{(2 - \frac{p \cdot l_o}{r})^2 - 4}}{2} < \exp\left(\frac{b_o \cdot (a - f_o)}{r} \right)$, then $f_o^* = 0$.
  - Otherwise, f_o^* satisfies following equation:

$$\exp\left(\frac{b_o \cdot (a - (f_o - f_o^*))}{r} \right) = \frac{\frac{p \cdot l_o}{r} - 2 + \sqrt{(2 - \frac{p \cdot l_o}{r})^2 - 4}}{2} \tag{38}$$

  If the insurer underwrites the service provider and customers, then optimal incentive factor f_o^{**} is given by,

  - If $\frac{p \cdot \left[l_o + \sum_{i=1}^{n} l_i \cdot \left(t - t \cdot E(P_i(f_i)) \right) \right]}{r} < 4$, then $f_o^{**} = 0$
  - If $\frac{p \cdot \left[l_o + \sum_{i=1}^{n} l_i \cdot \left(t - t \cdot E(P_i(f_i)) \right) \right]}{r} > 4$ and $\frac{\frac{p \cdot \left[l_o + \sum_{i=1}^{n} l_i \cdot \left(t - t \cdot E(P_i(f_i)) \right) \right]}{r} - 2 + \sqrt{\left(2 - \frac{p \cdot \left[l_o + \sum_{i=1}^{n} l_i \cdot \left(t - t \cdot E(P_i(f_i)) \right) \right]}{r} \right)^2 - 4}}{2} < \exp\left(\frac{b_o \cdot (a - f_o)}{r} \right)$, then $f_o^{**} = 0$
  - Otherwise, f_o^{**} satisfies following equation:

$$\exp\left(\frac{b_o \cdot (a - (f_o - f_o^{**}))}{r} \right) = \frac{\frac{p \cdot \left[l_o + \sum_{i=1}^{n} l_i \cdot \left(t - t \cdot E(P_i(f_i)) \right) \right]}{r} - 2 + \sqrt{\left(2 - \frac{p \cdot \left[l_o + \sum_{i=1}^{n} l_i \cdot \left(t - t \cdot E(P_i(f_i)) \right) \right]}{r} \right)^2 - 4}}{2} \tag{39}$$

  Because $\left[l_o + \sum_{i=1}^{n} l_i \cdot \left(t - t \cdot E(P_i(f_i)) \right) \right] \geq l_o$, then $f_o^{**} \geq f_o^*$ in this case as well.

- $p_o(f_o - f'_o) = q + p \exp\left(-\frac{b_o \cdot (a - (f_o - f'_o))}{r} \right)$, where p, q, r, a are constant and $p + q < 1$ and $f_o < a$.

  By the first order condition we have,

$$f_o^* = \left(f_o - a - \frac{r}{b_o} \ln \frac{r}{p \cdot l_o} \right)^+ \tag{40}$$

  Moreover, f_o^{**} is given by,

$$f_o^{**} = \left(f_o - a - \frac{r}{b_o} \ln \frac{r}{p \cdot \left[l_o + \sum_{i=1}^{n} l_i \cdot \left(t - t \cdot E(P_i(f_i)) \right) \right]} \right)^+ \tag{41}$$

All of the above examples imply that the insurer should offer higher discount factor when she underwrites the SP and the customers as compared to the optimal incentive factor which maximizes $\bar{V}_o(f'_o)$.

Downloaded from academic.oup.com/cybersecurity/article/5/1/tyz010/5601219 by guest on 18 October 2026